

INFORMATION SECURITY

GRC Risk Assessment Report

Organisation: True Security limited

Classification: CONFIDENTIAL

Date Generated: 2026-06-22

RiskCore Version: v1.0

Methodology: NIST SP 800-30 Rev 1

Overall Risk Posture: Critical

Frameworks Applied

- NIST Cybersecurity Framework (CSF)
- ISO/IEC 27001:2022 — Annex A Controls
- MITRE ATT&CK; Enterprise Framework
- CIS Critical Security Controls
- CIA Triad — Confidentiality, Integrity, Availability

Table of Contents

1. Executive Summary

2. Risk Overview

3. Risk Matrix

4. Risk Register

5. Detailed Risk Profiles

6. Recommendations

7. Methodology Appendix

Executive Summary

Metric	Value
Total Risks	10
Critical Risks	4
High Risks	4
Medium Risks	2
Low Risks	0
Open Risks	8
Closed Risks	0
Highest Risk	Unpatched Internet-Facing Server
Highest Risk Score	20
Most Common NIST Function	Protect
Most Common CIA Component	Confidentiality

Analyst Context

True Security limited's risk register currently contains 10 risks, with 4 rated Critical and 4 rated High. The highest-scoring risks are: Unpatched Internet-Facing Server; Missing MFA for VPN Access; Dormant Privileged Accounts. Risks span the following categories: Compliance, Operational, Technical, Third Party. Coverage currently concentrates on the Detect, Govern, Identify, Protect, Recover, Respond NIST CSF function(s).

Risk Overview

Risk Counts by Severity

Severity	Score Range	Count
Critical	15–25	4
High	10–14	4
Medium	5–9	2
Low	1–4	0

Risk Counts by Status

Status	Count
Open	8
In Progress	2
Mitigated	0
Accepted	0
Closed	0

Risk Counts by NIST CSF Function

NIST Function	Count
Identify	1
Protect	4
Detect	1
Respond	1
Recover	1

Risk Matrix

5×5 likelihood/impact heatmap per NIST SP 800-30. Each cell shows the risk score (Likelihood × Impact) and, where applicable, the number of register risks scored at that combination.

Likelihood ↓ / Impact →	Negligible (1)	Minor (2)	Moderate (3)	Major (4)	Critical (5)
Almost Certain (5)	5	10	15	20 (1)	25
Likely (4)	4	8	12 (2)	16 (2)	20
Possible (3)	3	6 (1)	9 (1)	12 (2)	15 (1)
Unlikely (2)	2	4	6	8	10
Rare (1)	1	2	3	4	5

■ LOW (1–4)

■ MEDIUM (5–9)

■ HIGH (10–14)

■ CRITICAL (15–25)

Risk Register

ID	Title	Score	Owner	Status	NIST	Source
1	Unpatched Internet-Facing Server	20	Infrastructure Team	Open	Protect	Manual
2	Missing MFA for VPN Access	16	Security Team	Open	Protect	Manual
3	Dormant Privileged Accounts	16	Identity Management Team	Open	Protect	Manual
5	Backup Recovery Testing Not Performed	15	Infrastructure Team	Open	Recover	Manual
4	Vendor Security Assessment Overdue	12	Vendor Management Team	Open	Govern	Manual
6	Endpoint Antivirus Outdated	12	Desktop Support Team	In Progress	Protect	Manual
7	Incomplete Asset Inventory	12	Asset Management Team	Open	Identify	Manual
8	Log Retention Gaps	12	SOC Team	In Progress	Detect	Manual
9	Missing Incident Response Training	9	Security Manager	Open	Respond	Manual
10	Security Awareness Training Completion Below Tar	6	Human Resources	Open	Govern	Manual

Detailed Risk Profiles

Risk #1 — CRITICAL (Score: 20)

Priority: Immediate

Title	Unpatched Internet-Facing Server
Description	Critical internet-facing web server is missing multiple security updates and is vulnerable to publicly disclosed exploits.
Category	Technical
Owner	Infrastructure Team
Status	Open
Priority	Immediate
Likelihood	5 — Very High
Impact	4 — Major
Inherent Score	20 (CRITICAL)
Residual Score	8
NIST Mapping	Protect › Technology Infrastructure Resilience [PR.PT-03]
ISO Mapping	A.8 Technological Controls · A.8.8
MITRE Mapping	Tactic: Initial Access Technique: T1190 Exploit Public-Facing Application
CIS Mapping	CIS-7
CIA Mapping	Confidentiality
Existing Controls	Monthly patch management process
Mitigation Plan	Apply all outstanding security updates and implement automated vulnerability scanning.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	Production customer-facing server.

Risk #2 — CRITICAL (Score: 16)

Priority: Immediate

Title	Missing MFA for VPN Access
Description	Remote users can authenticate to the corporate VPN using only usernames and passwords. Compromised credentials could allow attackers to gain unauthorized access to internal systems and sensitive information.
Category	Technical
Owner	Security Team
Status	Open
Priority	Immediate
Likelihood	4 — High
Impact	4 — Major
Inherent Score	16 (CRITICAL)
Residual Score	6
NIST Mapping	Protect › Identity Management & Access Control [PR.AA-01]

ISO Mapping	A.8 Technological Controls · A.8.5
MITRE Mapping	Tactic: Credential Access Technique: T1078 Valid Accounts
CIS Mapping	CIS-6
CIA Mapping	Confidentiality
Existing Controls	Password policy enforced
Mitigation Plan	Implement MFA for all VPN users.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	Remote workforce risk.

Risk #3 — CRITICAL (Score: 16)

Priority: Short-term

Title	Dormant Privileged Accounts
Description	Several privileged accounts belonging to former employees and inactive contractors remain enabled. These accounts could be exploited by attackers to gain elevated access to critical systems.
Category	Compliance
Owner	Identity Management Team
Status	Open
Priority	Short-term
Likelihood	4 — High
Impact	4 — Major
Inherent Score	16 (CRITICAL)
Residual Score	7
NIST Mapping	Protect › Identity Management & Access Control [PR.AA-05]
ISO Mapping	A.8 Technological Controls · A.8.2
MITRE Mapping	Tactic: Persistence Technique: T1078 Valid Accounts
CIS Mapping	CIS-5
CIA Mapping	Confidentiality
Existing Controls	User provisioning process
Mitigation Plan	Quarterly access reviews and automatic account disablement.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	Several inactive administrative accounts identified.

Risk #5 — CRITICAL (Score: 15)

Priority: Immediate

Title	Backup Recovery Testing Not Performed
Description	Although backups are performed regularly, recovery procedures have not been tested. The organization cannot confidently verify that systems and data can be restored during a major disruption.
Category	Operational
Owner	Infrastructure Team

Status	Open
Priority	Immediate
Likelihood	3 — Moderate
Impact	5 — Critical
Inherent Score	15 (CRITICAL)
Residual Score	6
NIST Mapping	Recover › Incident Recovery Plan Execution [RC.RP-01]
ISO Mapping	A.5 Organisational Controls · A.5.30
MITRE Mapping	Tactic: Impact Technique: e.g. T1078 Valid Accounts
CIS Mapping	CIS-11
CIA Mapping	Availability
Existing Controls	Daily backups
Mitigation Plan	Conduct recovery exercises every 6 months.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	Recovery process has never been validated.

Risk #4 — HIGH (Score: 12)

Priority: Short-term

Title	Vendor Security Assessment Overdue
Description	A critical third-party service provider has not undergone a cybersecurity risk assessment within the required review period. Security weaknesses within the vendor environment may introduce supply chain risks.
Category	Third Party
Owner	Vendor Management Team
Status	Open
Priority	Short-term
Likelihood	3 — Moderate
Impact	4 — Major
Inherent Score	12 (HIGH)
Residual Score	5
NIST Mapping	Govern › Cybersecurity Supply Chain Risk [GV.SC-01]
ISO Mapping	A.5 Organisational Controls · A.5.19
MITRE Mapping	Tactic: Initial Access Technique: T1199 Trusted Relationship
CIS Mapping	CIS-15
CIA Mapping	Confidentiality
Existing Controls	Annual vendor review process
Mitigation Plan	Complete assessment and risk ranking.
Created Date	2026-06-22
Last Modified	2026-06-22

Notes	Critical SaaS provider overdue for review.
-------	--

Risk #6 — HIGH (Score: 12)		Priority: Short-term
Title	Endpoint Antivirus Outdated	
Description	Multiple workstations have outdated antivirus signatures and software versions, reducing the organization's ability to detect and prevent modern malware threats.	
Category	Technical	
Owner	Desktop Support Team	
Status	In Progress	
Priority	Short-term	
Likelihood	4 — High	
Impact	3 — Moderate	
Inherent Score	12 (HIGH)	
Residual Score	5	
NIST Mapping	Protect › Platform Security [PR.PT-04]	
ISO Mapping	A.8 Technological Controls · A.8.7	
MITRE Mapping	Tactic: Execution Technique: T1204 User Execution	
CIS Mapping	CIS-10	
CIA Mapping	Integrity	
Existing Controls	Centralized AV platform	
Mitigation Plan	Force signature updates and monitor compliance.	
Created Date	2026-06-22	
Last Modified	2026-06-22	
Notes	18 workstations out of date.	

Risk #7 — HIGH (Score: 12)		Priority: Medium-term
Title	Incomplete Asset Inventory	
Description	The organization lacks a complete and accurate inventory of hardware, software, and cloud assets. Untracked assets may contain vulnerabilities and create visibility gaps for security monitoring.	
Category	Operational	
Owner	Asset Management Team	
Status	Open	
Priority	Medium-term	
Likelihood	4 — High	
Impact	3 — Moderate	
Inherent Score	12 (HIGH)	
Residual Score	4	
NIST Mapping	Identify › Asset Management [ID.AM-01]	
ISO Mapping	A.5 Organisational Controls · A.5.9	

MITRE Mapping	Tactic: Reconnaissance Technique: e.g. T1078 Valid Accounts
CIS Mapping	CIS-1
CIA Mapping	Availability
Existing Controls	Manual inventory spreadsheet
Mitigation Plan	Deploy automated asset discovery.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	Cloud assets not fully tracked.

Risk #8 — HIGH (Score: 12)

Priority: Medium-term

Title	Log Retention Gaps
Description	Security logs are not retained for the required period, limiting the ability to investigate incidents, support forensic analysis, and meet compliance obligations.
Category	Operational
Owner	SOC Team
Status	In Progress
Priority	Medium-term
Likelihood	3 — Moderate
Impact	4 — Major
Inherent Score	12 (HIGH)
Residual Score	4
NIST Mapping	Detect › Continuous Monitoring [DE.CM-01]
ISO Mapping	A.8 Technological Controls · A.8.15
MITRE Mapping	Tactic: Defense Evasion Technique: T1070 Indicator Removal on Host
CIS Mapping	CIS-8
CIA Mapping	Integrity
Existing Controls	SIEM platform
Mitigation Plan	Extend retention to 12 months.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	Regulatory retention requirement not met.

Risk #9 — MEDIUM (Score: 9)

Priority: Medium-term

Title	Missing Incident Response Training
Description	Personnel responsible for incident response have not participated in formal training or tabletop exercises within the last year, reducing preparedness during a cybersecurity incident.
Category	Operational
Owner	Security Manager
Status	Open

Priority	Medium-term
Likelihood	3 — Moderate
Impact	3 — Moderate
Inherent Score	9 (MEDIUM)
Residual Score	3
NIST Mapping	Respond › Improvements [RS.RP-01]
ISO Mapping	A.6 People Controls · A.6.3
MITRE Mapping	Tactic: Impact Technique: T1485 Data Destruction
CIS Mapping	CIS-17
CIA Mapping	Availability
Existing Controls	Incident Response Plan
Mitigation Plan	Conduct annual tabletop exercises.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	No exercises completed in last 12 months.

Risk #10 — MEDIUM (Score: 6) Priority: Medium-term	
Title	Security Awareness Training Completion Below Target
Description	A significant portion of employees have not completed mandatory cybersecurity awareness training, increasing the likelihood of successful phishing attacks and human-error-related incidents
Category	Compliance
Owner	Human Resources
Status	Open
Priority	Medium-term
Likelihood	3 — Moderate
Impact	2 — Minor
Inherent Score	6 (MEDIUM)
Residual Score	2
NIST Mapping	Govern › Roles & Responsibilities [GV.RR-01]
ISO Mapping	A.6 People Controls · A.6.3
MITRE Mapping	Tactic: Initial Access Technique: T1566 Phishing
CIS Mapping	CIS-14
CIA Mapping	Confidentiality
Existing Controls	Annual awareness training
Mitigation Plan	Increase completion rate to 95%.
Created Date	2026-06-22
Last Modified	2026-06-22
Notes	Current completion rate is 72%.

Recommendations

1.	Review all 4 Critical risk(s) immediately, starting with: Unpatched Internet-Facing Server, Missing MFA for VPN Access, Dormant Privileged Accounts.
2.	Prioritise remediation of 4 High-severity risk(s) within the next 30–90 days.
3.	8 risk(s) remain in Open status — assign owners and target dates where missing.
4.	5 risk(s) affect Confidentiality — confirm data classification and access controls are reviewed.
5.	3 risk(s) affect Availability — verify business continuity and recovery plans cover these areas.

Methodology Appendix

Risk Scoring Formula

RiskCore calculates **Inherent Risk Score** = **Likelihood** × **Impact**, each rated on a 1–5 scale per NIST Special Publication 800-30 Revision 1, producing a score from 1 to 25. **Residual Score** reflects the risk remaining after existing controls are applied.

Severity Bands

Score Range	Severity	Typical Response Time
15–25	Critical	Immediate (0–30 days)
10–14	High	Short-term (30–90 days)
5–9	Medium	Medium-term (90–180 days)
1–4	Low	Ongoing monitoring

Frameworks Used

NIST Cybersecurity Framework (CSF) 2.0	Functions: Govern, Identify, Protect, Detect, Respond, Recover
ISO/IEC 27001:2022	Annex A: A.5 Organisational, A.6 People, A.7 Physical, A.8 Technological
MITRE ATT&CK; Enterprise	Adversary tactics and techniques
CIS Critical Security Controls	Practical, prioritised security safeguards
CIA Triad	Confidentiality, Integrity, Availability impact classification

This report was generated by RiskCore GRC Platform v1.0 on 2026-06-22 14:54. Classification: CONFIDENTIAL. All figures in this report are computed directly from the risk register at the time of generation.